YUKTHI 2026

TEAM: BRUTE FORCE

SupplyGraph

BLOCKCHAIN & CYBERSECURITY TRACK

Zero-Trust Software Supply-Chain Attack Graph | AI Code Reviewer | Universal Sandbox Platform

WORKING PROTOTYPE — LIVE & DEPLOYED

https://supplygraph-five.vercel.app

STATUS: 128/128 Automated Pytest Tests Passing (100% Verified)

2 Problem Statement

The AI Code Crisis & Software Supply-Chain Vulnerability Epidemic

OWASP: 50% AI CODE = VULNERABLE

AI-Generated Code Is Insecure By Default

01

Developers use AI coding tools (GitHub Copilot, ChatGPT) to generate production code at scale without security review. OWASP AI Security Research demonstrates that 45-50% of AI-generated code contains critical vulnerabilities: injection flaws, broken access control, hardcoded credentials, and insecure deserialization.

Open-Source Dependency Explosion

02

Modern applications inherit 85-90% of their codebase from open-source packages (npm, PyPI, Go, Cargo). AI code generators blindly pull vulnerable transitive libraries — a single compromised or unpatched package nested 4 hops deep can compromise the entire production software supply chain.

Traditional Scanners Are Blind to Transitive Threats

03

Flat vulnerability scanners (npm audit, Dependabot, Snyk) produce severe alert fatigue and CANNOT trace multi-hop transitive exploit paths. They fail to determine if a CVE is reachable in production code execution, leaving developers overwhelmed by hundreds of disconnected alerts without attack-path context.

Malicious Build Hooks Bypass Static Analysis

04

Static analyzers cannot safely inspect malicious postinstall lifecycle scripts (package.json hooks), setup.py routines, or compiled binaries (PE .exe, ELF .elf, WASM .wasm) without executing them — exposing host development machines and CI runners to reverse shells and credential theft at install time.

No Cryptographic Proof of Software Integrity

05

Organizations lack tamper-evident, blockchain-verifiable proof of software composition (SBOM) for compliance audit. Without immutable on-chain attestation, teams cannot cryptographically satisfy zero-trust compliance mandates including SLSA Level 3, SSDF, Executive Order 14028 SBOM requirements, and NIST SP 800-218.

3 Proposed Solution

SupplyGraph v3.5: Autonomous ASPM & Universal Sandbox Platform

DEPENDENCY ATTACK GRAPH ENGINE

01 Constructs a full Reverse Directed Acyclic Graph (DAG) using NetworkX across npm, PyPI, Go, and Rust. Traces every transitive dependency (up to 10 hops) to compute exact Blast Radius B = min(100, 2P+15S+25A+50D) and Confidence C = 1-Prod(1-w_i*r_i). Rendered as 633-node interactive graph at 60 FPS via React Flow virtualization.

AI-POWERED AUTOMATED CODE REVIEW (<50ms AST)

02 Google Gemini 1.5 Flash + Custom Python AST & Token-Sanitized Pattern Engine perform multi-file security analysis in under 50ms per file (Python, JS, Go, Rust). Detects SQL injection, XSS, SSRF, path traversal, and hardcoded secrets. Auto-generates unified diff patches applied to repo as GitHub PR in 1 click.

UNIVERSAL BEHAVIORAL SANDBOX (Zero Network Egress)

03 Safely detonates npm postinstall hooks, setup.py scripts, and compiled binaries (PE .exe, ELF .elf, WebAssembly .wasm) in an ephemeral Docker container: --network none, 512MB RAM, 10s CPU timeout, seccomp profile. Captures strace syscalls, file-I/O (inotify), and network attempts. Zero host exposure.

CI/CD PIPELINE SECURITY AUDITOR (SLSA + MITRE)

04 Parses GitHub Actions / GitLab CI / Jenkins YAML configurations. Flags: unpinned action SHAs, curl|bash execution patterns, write-all permissions, OIDC token misuse, and self-hosted runner risks. Maps findings to SLSA Level violations and MITRE ATT&CK for CI/CD TTP identifiers. Generates least-privilege PRs.

POLYGON BLOCKCHAIN SBOM ATTESTATION (CycloneDX SHA-256)

05 Anchors CycloneDX 1.5 SBOM SHA-256 Merkle root hash on Polygon PoS testnet via Web3.py smart contract. Every scan emits a tamper-evident on-chain record: SBOM hash + scan timestamp + repo commit SHA + tx hash. Satisfies EO 14028, SSDF, NIST SP 800-218, and SLSA Level 3 zero-trust compliance requirements.

4 Key Features

CORE CAPABILITIES — 5 Integrated Security Modules

Attack Graph Visualization (60 FPS / 633 Nodes)

F1

NetworkX Reverse DAG renders 633 nodes & 891 edges at 60 FPS via React Flow virtualization. Blast Radius B=0-100; Confidence score C=0-100%. CVE drill-down, attack-path heat-map, one-click overlay.

AI Code Review Engine (<50ms AST per file)

F2

Custom Python AST & Token-Sanitized Pattern Engine scans files in <50ms/file across Python, JS, Go, Rust. Gemini 1.5 Flash + Pattern matching detect SQL injection, XSS, SSRF, path traversal, hardcoded secrets. Auto-generates unified diff patches as PR.

Universal Behavioral Sandbox (--network none)

F3

Docker seccomp container: --network none, 512MB RAM, 10s timeout. Detonates npm postinstall hooks, setup.py, PE .exe, ELF .elf, WASM .wasm binaries. Captures syscalls + file-I/O + network. Zero host risk.

Blockchain SBOM Attestation (Polygon PoS Testnet)

F4

CycloneDX 1.5 SBOM SHA-256 Merkle root anchored on Polygon PoS testnet via Web3.py smart contract. Each scan emits an immutable on-chain tx hash + Polygon explorer link. Satisfies EO 14028 + SLSA L3.

CI/CD Pipeline Auditor (SLSA + MITRE ATT&CK)

F5

Parses GitHub Actions / GitLab CI YAML. Flags curl|bash, write-all, unpinned SHAs, OIDC misuse. Maps to SLSA Level violations and MITRE ATT&CK for CI/CD TTP IDs. Generates least-privilege PRs.

SUPPLYGRAPH vs EXISTING TOOLS

Feature	SupplyGraph	Snyk	Dep.	Sonar
Interactive Attack-Path DAG	✅ Yes	⚠ Partial	❌ No	❌ No
Blast Radius Score (0-100)	✅ Yes	⚠ Partial	❌ No	❌ No
Behavioral Runtime Sandbox	✅ Yes	❌ No	❌ No	❌ No
AI Code Review & Patching	✅ Yes	⚠ Partial	❌ No	⚠ Partial
Blockchain SBOM Attestation	✅ Yes	❌ No	❌ No	❌ No
CI/CD Workflow YAML Audit	✅ Yes	⚠ Partial	⚠ Partial	⚠ Partial
4-Ecosystem Lockfile Graph	✅ Yes	✅ Yes	✅ Yes	⚠ Partial
Instant Browser Folder Upload	✅ Yes	❌ No	❌ No	❌ No
Reverse-DAG Reachability	✅ Yes	⚠ Partial	❌ No	❌ No
Binary C2 String Extraction	✅ Yes	❌ No	❌ No	❌ No

5 Implementation Approach

4-Stage Security Pipeline — End-to-End Autonomous Supply-Chain Analysis

STAGE 1 — INGEST & SBOM GENERATION

✓ Validated on vercel/next.js — 500 Components Scanned

>> **Core Ingestion Pipeline:** Multi-ecosystem parsing (package.json, requirements.txt, go.mod, Cargo.lock) + CycloneDX 1.5 SBOM generation + Offline folder upload.

>> **Transitive Tree Resolution:** Normalizes canonical PURLs across npm, PyPI, Go, and Cargo; resolves full transitive dependency tree (up to 10 hops) with zero host execution.

STAGE 2 — MULTI-VECTOR THREAT ANALYSIS

✓ Validated on axios/axios — 60 AI Code Review Findings

>> **Threat Intelligence & AST:** OSV.dev batch CVE correlation + Token-sanitized AST code inspection (<50ms) + Levenshtein typosquatting & dependency confusion checks.

>> **Multi-Language Parser:** tree-sitter AST syntax engine across Python, JS, Go, Rust; flags SQLi, XSS, SSRF, hardcoded secrets, and CI/CD workflow security risks.

STAGE 3 — GRAPH CONSTRUCTION & RISK SCORING

✓ Validated on wasmtime — 94 Components & 16 Findings

>> **Attack Graph Modeling:** NetworkX Directed Acyclic Graph (DAG) construction + Multi-hop reverse reachability tracing + Deterministic Blast Radius scoring (0–100).

>> **Exact Mathematical Scoring:** Traces multi-hop exploit paths from origin CVE to production assets; computes exact Blast Radius B = min(100, 2P+15S+25A+50D) and Confidence C.

STAGE 4 — SANDBOX, AUTO-PATCH & BLOCKCHAIN ATTEST

✓ 128/128 Automated Pytest Suite Passing (100% Verified)

>> **Behavioral Runtime Detonation:** Ephemeral Docker container detonation (--network none, 512MB RAM, 10s limit) + Post-install hook & binary string extraction.

>> **Remediation & Attestation:** Gemini 1.5 Pro generates unified diff remediation PRs; anchors CycloneDX 1.5 SBOM SHA-256 Merkle root on Polygon PoS testnet.

6 Technology Stack

Full-Stack Engineering Blueprint — Unified, Deployed Cyber Security Pipeline

UI LAYER	Next.js 14 + App Router	React Flow 11 60-FPS Graph	Tailwind CSS shadcn/ui	Recharts Dashboards
API LAYER	FastAPI Python 3.12	Pydantic v2 Validation	SQLAlchemy 2 Async ORM	Uvicorn ASGI
ANALYSIS ENGINE	NetworkX 3.x DAG Engine	Python AST Token-Sanitized AST	Custom SBOM Gen CycloneDX 1.5	OSV.dev API CVE Intel
AI / SANDBOX	Gemini 1.5 Flash AI Review	AST Auto-Patcher Code Patch	Docker SDK --network none	5-Layer Threat Engine
STORAGE / CHAIN	Supabase PostgreSQL 15	Web3.py Polygon PoS Testnet	Alembic Migrations	GitHub Actions 128/128 CI

LIVE DEPLOYMENT (https://supplygraph-five.vercel.app): Vercel (Next.js 14 Frontend) >> Render Python 3.12 (FastAPI Backend) >> Docker Isolated Sandbox (--network none, 512MB RAM, 10s Limit) >> Supabase PostgreSQL 15 >> Polygon PoS Testnet (CycloneDX SBOM Anchor) >> GitHub Actions (128/128 Pytest CI Passing)